

TÓM TẮT SÁNG KIẾN

Tên sáng kiến: Secure Mail — Giải pháp mã hóa đầu cuối thư điện tử trên nền Gmail, bản địa hóa tiếng Việt, phục vụ giảng dạy và công tác bảo đảm an toàn thông tin

Tác giả: [Họ và tên] — Giảng viên An toàn thông tin trên không gian mạng, [Tên đơn vị]

Lĩnh vực: Công nghệ thông tin — An toàn thông tin

1. Vấn đề

Thư điện tử thông thường chỉ được mã hóa **trên đường truyền**. Tại máy chủ của nhà cung cấp, thư nằm ở dạng rõ trong suốt thời gian lưu trữ. Mọi tài liệu nghiệp vụ, đề thi chưa công bố, dữ liệu cá nhân của người học gửi qua thư điện tử đều tồn tại ở dạng đọc được trên một hạ tầng mà đơn vị không kiểm soát.

Song song, công tác giảng dạy An toàn thông tin thiếu một công cụ để người học thực hành mật mã ứng dụng: các phần mềm mã hóa đầu cuối hiện có đều chỉ có giao diện tiếng Anh, với hệ thuật ngữ chưa chuẩn hóa sang tiếng Việt.

2. Hạn chế của các giải pháp đã biết

Bảng tóm tắt hiện trạng

Nhóm giải pháp	Hạn chế chưa khắc phục
Dịch vụ thư bảo mật (Proton, Tuta)	Phải chuyển toàn bộ hộp thư sang nhà cung cấp nước ngoài; khóa riêng tư lưu trên máy chủ của họ
S/MIME	Cần hạ tầng chứng thực số; không dùng được với giao diện web
GnuPG + máy khách thư	Rào cản sử dụng rất cao; không tích hợp webmail; chỉ tiếng Anh
Tiện ích trình duyệt (Mailvelope, FlowCrypt)	Không có tiếng Việt; không chọn được ngôn ngữ; mặc định tra cứu máy chủ khóa nước ngoài; kèm thư viện đo lường từ xa; chặn tài khoản Google Workspace bằng kiểm tra giấy phép thương mại; xác thực OAuth không có PKCE; định danh tiện ích không cố định nên không triển khai được

3. Giải pháp

Secure Mail là tiện ích trình duyệt bổ sung lớp mã hóa đầu cuối OpenPGP ngay trong giao diện Gmail. Bản rõ được mã hóa trên máy người dùng trước khi giao cho Gmail; khóa riêng tư không bao giờ rời khỏi máy trạm. **Không phải đổi nhà cung cấp thư, không cần hạ tầng mới, không cần chứng thư số.**

Sáng kiến xây dựng trên nền mã nguồn mở Mailvelope 6.3.0 (AGPL-3.0), giữ nguyên lõi mật mã đã được kiểm chứng, và giải quyết toàn bộ những hạn chế nêu trên.

4. Năm điểm mới

1. **Trình khách OpenPGP hoàn chỉnh bằng tiếng Việt** — 586/586 chuỗi, độ phủ 100%, kèm bộ thuật ngữ mật mã tiếng Việt được chuẩn hóa và kiểm tra nhất quán bằng công cụ. Tiếng Việt là ngôn ngữ duy nhất đạt 100% ngoài tiếng Anh; sản phẩm gốc có 15 ngôn ngữ và không có tiếng Việt.
2. **Cơ chế chọn ngôn ngữ trong ứng dụng** — thay lớp phân giải chuỗi để người dùng chọn ngôn ngữ độc lập với trình duyệt, vượt qua giới hạn kiến trúc của nền tảng mà không phá vỡ cơ chế đa ngữ sẵn có.
3. **Mô hình tin cậy khép kín** — tắt toàn bộ bốn cơ chế tra cứu máy chủ khóa bên ngoài, chuyển trách nhiệm xác nhận danh tính về đơn vị, kèm quy trình quản trị được tài liệu hóa.
4. **Loại bỏ triệt để phụ thuộc bên thứ ba** — gỡ khỏi mã nguồn thư viện đo lường từ xa và cơ chế kiểm tra giấy phép thương mại. Kết quả: sản phẩm không liên lạc với máy chủ nào ngoài chính Gmail, và điều đó kiểm tra lại được bằng một lệnh trên gói phát hành. Việc này đồng thời **mở khóa khả năng sử dụng cho tài khoản Google Workspace** — loại tài khoản mà cơ quan sẽ dùng, vốn bị bản gốc chặn.
5. **Kiến trúc mở rộng sang di động** giữ nguyên lõi mật mã đã kiểm chứng, chứng minh tương đương bằng phép thử đối chứng.

5. Điểm sáng tạo về phương pháp

Biến mọi khẳng định an toàn thành một phép kiểm tra chạy lại được. Trong tài liệu sản phẩm bảo mật, những câu như "không thu thập dữ liệu" gần như không bao giờ kiểm chứng được. Sáng kiến áp dụng nguyên tắc ngược lại: mỗi khẳng định đi

kèm một lệnh để người khác bác bỏ nó. Năm kịch bản kiểm chứng được cung cấp cùng sản phẩm.

Chính phương pháp đó đã tự phát hiện sáu lỗi dịch thuật — trong đó hai lỗi làm mất khuyến cáo an toàn — và ba phép thử hỏng. Tất cả đã được sửa.

6. Kết quả đo được

Bảng kết quả chính

Chỉ tiêu	Kết quả
Kiểm thử tự động	517/517 đạt (449 bản máy tính, 68 bản di động)
Liên thông với GnuPG 2.4.4	8/8 phép thử đạt — bí mật, xác thực, chữ ký tách rời, phát hiện sửa đổi, cả hai chiều
Kiểm toán bề mặt mạng trên gói phát hành	4/4 điểm cuối bên thứ ba đã gỡ: vắng mặt
Độ phủ bản dịch tiếng Việt	586/586 = 100%, 0 lỗi chặn
Độ trễ mã hóa một bức thư thông thường	15–36 ms — dưới ngưỡng cảm nhận
Mã hóa tệp đính kèm 5 MB	404 ms
Sinh cặp khóa RSA-4096 qua giao diện thật	8–10 giây , chỉ thực hiện một lần

7. Khả năng áp dụng

Không cần hạ tầng, không cần máy chủ, không cần chứng thư số. Chỉ cần trình duyệt Chrome hoặc Edge từ phiên bản 122 — đã có sẵn trên hầu hết máy trạm. Cài đặt bằng cách nạp gói vào trình duyệt; có hướng dẫn tiếng Việt kèm ảnh minh họa.

Áp dụng ngay cho: giảng dạy và thực hành An toàn thông tin; bảo vệ tài liệu giảng dạy, đề thi chưa công bố, kết quả học tập; trao đổi nghiệp vụ nội bộ theo quy chế đơn vị; trao đổi dữ liệu nghiên cứu chưa công bố.

8. Phạm vi — nêu rõ để không có hiểu nhầm

Secure Mail **chưa được kiểm định, chưa được cấp phép và không được đề xuất** để truyền, nhận thông tin thuộc danh mục bí mật nhà nước. Việc đó phải sử dụng sản phẩm mật mã và tuân thủ quy định về cơ yếu (Luật Bảo vệ bí mật nhà nước 2018; Nghị định 26/2020/NĐ-CP). Hồ sơ khẳng định **năng lực kỹ thuật**, không khẳng định **tư cách pháp lý**. Việc một giải pháp dùng thuật toán mạnh không tự nó tạo ra tư cách pháp lý cho mục đích trên.

Sáng kiến cũng chưa được triển khai diện rộng, nên **chưa có hiệu quả kinh tế đã thực hiện** để báo cáo; phần hiệu quả trong hồ sơ được ghi rõ là dự kiến, nêu căn cứ, và không quy đổi thành con số khi chưa có cơ sở.

9. Mức độ hoàn thành

Tiện ích máy tính, tích hợp Gmail, bản địa hóa, cải tạo mô hình tin cậy, xác thực an toàn, bộ công cụ kiểm chứng và tài liệu vận hành: **đã hoàn thành và kiểm thử**. Nền tảng kỹ thuật cho bản di động: **đã hoàn thành, 68/68 phép thử đạt**. Giao diện di động và tích hợp Gmail trên di động: giai đoạn tiếp theo. Triển khai thí điểm: **chưa thực hiện** — là việc cần làm ngay.

10. Vì sao đề nghị Hội đồng đánh giá cao

- Giải quyết một **vấn đề có thật** trong công tác, không phải một bài toán được dựng lên.
- **Mọi số liệu đều đo được và tái lập được**; hồ sơ cung cấp kèm công cụ để Hội đồng tự kiểm chứng thay vì phải tin tác giả.
- **Trung thực về giới hạn**: nêu rõ ranh giới pháp lý, nêu rõ những gì chưa có, không quy đổi hiệu quả kinh tế khi chưa có căn cứ.
- **Có giá trị kép**: vừa là công cụ bảo vệ thông tin, vừa là học cụ; bộ thuật ngữ mật mã tiếng Việt dùng lại được cho giáo trình và các phần mềm khác.
- **Nhân rộng được ngay** vì không đòi hỏi hạ tầng, có tài liệu đầy đủ bằng tiếng Việt và quy trình xây dựng lặp lại được.